# Databaseprogrammering og sikkerhed

## Indhold


Faglige mål ..... 2

Målpind som dagens øvelse dækker ..... 2

Baggrund ..... 3

Øvelse ..... 4

1. Vælg data strategi ..... 4
2. Indsæt data i din database ..... 4
3. Rettighedsstyring ..... 4
4. Validering af data ..... 5
5. Stored Procedures ..... 5
6. Fejlhåndtering ..... 5

Hvordan du bliver bedømmet ..... 5

# Faglige mål

## Målpind som dagens øvelse dækker

10. ***Eleven kan anvende avancerede SQL-kommandoer som parametre, kontrolstrukturer, rettighedsstyring o.l.**
11. **Eleven kan redegøre for baggrunden for konsistenskrav, referenceintegritet, relationer og forskellige constraints.**
12. ***Eleven kan oprette, redigere og slette Stored Procedures med et administrations- og databehandlingsformål.**
13. **Eleven kan oprette og administrere Triggers med henblik på at holde databasen konsistent.**
14. ***Eleven kan træffe korrekte forholdsregler til at imødegå SQL Injection.**
15. *Eleven kan oprette og administrere indexes så der opnås optimal performance.*
16. *Eleven kan udføre performance-måling på en stor database.*
17. **Eleven kan normalisere en database.**

# Baggrund

Din database skal kunne bruges af en applikation. Applikationen skal kunne udføre bestemte handlinger på databasen, men den skal samtidig være sikker.

Når en applikation arbejder med en database, er det vigtigt både at kunne **programmere databasen** og **beskytte den mod uønsket adgang og fejl**. Der er mange områder at fokuser på mht at beskytte databasen som denne fag ikke inkluder så som kryptografi og anonymisering (*må gerne kikke på af eget interrasse*), men til dette fag er det dog et krav at du fokuser på:

- SQL Injection
- Brugere og rettigheder
- Sikker databasekommunikation
- Validering
- Håndtering af fejl

# Øvelse

Genbrug din .NET-applikation fra forrige øvelse.

## 1. Vælg data strategi

Du skal tag udgangspunkt i den database, du udviklede i øvelse 1. Du vælger selv hvilket af følgende database teknologi du vil anvend til kommunikation med din database fra din .NET-applikation:

- ADO.net
- Dapper
- Entity Framework Core
- Blanding af en eller flere teknologier nævn foroven.

## 2. Indsæt data i din database

2.1. Indsæt, såvel som opdatering af data i databasen fra en applikation med brugerinput er en funktionalitet, som typisk kan være udsat for **SQL Injection**.

Udvid din applikation, så den kan modtage brugerinput der anvende en **INSERT** eller **UPDATE**-kommando til at indsætte brugerens data i databasen. Du skal anvende en teknik, der beskytter din SQL-kommando mod **SQL Injection**.

2.2. Reflektér over din løsning.
Du vil blive spurgt ind til hvordan du gemning data i din database med SQL INSERT/UPDATE kommandoer fra din programmerings kode og hvilket **sikkerheds forholdsregler** du anvender mod **SQL injection** og hvorledes den forholdregel virker til beskyttelse mod SQL injection. Formålet er at vurdere, hvor godt du forstår SQL injection truselen, hvad du kan gøre samt hvordan det du implementer mod SQL injection virker. Vurdering anvendes som en del af det samlede vudering ved karaktergivning.

## 3. Rettighedsstyring

3.1. Adgang til en database fra en applikation skal begrænses (LeastPrivilege), så brugere og applikationer kun har adgang til de data og funktioner, som de har behov for. For brede adgangsrettigheder kan blandt andet medføre, at en bruger eller applikation kan læse, ændre eller slette data, som den ikke bør have adgang til.

Udvid din applikation og database, så adgangen til databasen er begrænset på en måde, der beskytter data mod uautoriseret adgang eller ændringer.

Undersøg, hvordan du kan styre, **hvem der har adgang til databasen, og hvilke handlinger de må udføre**. Implementér en løsning, hvor der ingår en burger "admin". Kun admin må slette en "record", alle andre burger må gerne Creat, Read, og Update.

3.2. Reflektér over din løsning.
Du vil blive spurgt ind til, hvordan din applikation får adgang til databasen, hvordan du har begrænset adgangen, og hvilke **sikkerhedsforanstaltninger** du anvender for at beskytte databasen mod uautoriseret adgang (mod sletning). Du skal f.ex. demonstrere sletning af en "record" fra databasen og vise at kun "admin" bruger kan slette. Vurdering anvendes som en del af det samlede vudering ved karaktergivning.

## 4. Validering af data

4.1. Når data nu bliver opret, update med brugerindput, overvej om der er behov for at opdater din forretningsregler og constrains fra forrige øvelse. F.ex. validering af brugerindput, format, lovlig/ulovlig chr osv.

4.2. Reflektér over din løsning.
Du vil blive spurgt ind til, hvorfor validering af brugerinput er vigtigt før data indsættes i databasen og hvorledes man eventuelt kan håndhæve disse valideringsregler. Formålet er at vurdere, hvor godt du forstår validering af brugerinput og de teknikker du har implementeret. Vurdering anvendes som en del af det samlede vudering ved karaktergivning.

## 5. Stored Procedures

5.1. Overvej hvilket procedure har det bedst at ligge udenfor din app og i stedet i databasen så de kan ændres uden at du skal gen-kompilere din kode. Det er ikke kun data relavate for kunden, men også data som er i din interrasse at kunne ændres udenfor din kode. Implementér mindst **1 Stored Procedures** til din SQL Server som skal:

- modtage mindst én parameter (overveje SQL injection)
- hente eller ændre data
- indeholde relevant fejlhåndtering eller validering

5.2. Du vil blive spurgt ind til, hvad stored procedure er, forståelse af dens syntakser og kontrolstruktur samt anvendelse. Vurdering anvendes som en del af det samlede vudering ved karaktergivning.

## 6. Fejlhåndtering

6.1. Undersøg de forskellige exceptions rettet mod databaser. Implementer derefter fejlhåndtering hvor din throw/catch giver brugeren en meningsfuld besked med brug exceptions rettet mod databaser.

6.2. Reflektér over din løsning.
Du vil blive spurgt ind til brug af exception håndtering med exceptions rettet mod databaser. Formålet er at vurdere, hvor godt du forstår, at der er exceptions i din frameworks rettet mod kode som køre mod databaser. Vurdering anvendes som en del af det samlede vudering ved karaktergivning.

# Hvordan du bliver bedømmet

- Du skal fremvis kørsel af din app.
- Opgave indeholder en “refleksion” øvelse.
  - Du bliver bedømmet via spørgsmåler stillet med udgangspunkt i refleksionen af din øvelser.